

Threat Analysis Report

รายงานวิเคราะห์ ชุดเครื่องมือ WebShell
readme.php ของกลุ่ม NXBBSEC

15/11/2025

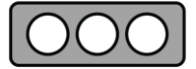
TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Technique Tactics and Procedures (MITRE ATT&CK).....	7
Indicator of Compromise (IOCs).....	8
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	9



บทสรุปสำหรับผู้บริหาร

เมื่อวันที่ 15 พฤศจิกายน 2568 กลุ่ม NXBBSEC เผยแพร่เครื่องมือ WebShell ที่ถูกฝังบนเว็บไซต์ hxxps://agx.vn/readme[.]php ใช้ชื่อไฟล์ readme.php จากการตรวจสอบพบว่าเป็นเครื่องมือ Webshell ชนิด WSO Version 2.5 ที่ผู้ไม่ประสงค์ดี upload เข้ามาเพื่อยึดครองสิทธิ์การควบคุมระบบจากระยะไกล โดยผู้ไม่ประสงค์ดีมีจุดประสงค์ในการใช้เครื่องเป้าหมายเป็นฐานสำหรับทำ SEO Poisoning โดยการสร้างไฟล์และโพสเตอร์ขยะจำนวนมากเพื่อหลอกลวง Search Engine และพบการรั่วไหลของข้อมูล (Data Exfiltration) เนื่องจากพบไฟล์สำรองฐานข้อมูล (.sql.gz) ถูกทิ้งไว้ในพื้นที่สาธารณะที่บุคคลภายนอกสามารถดาวน์โหลดได้

(ภาพเว็บไซต์ที่ถูกฝัง WebShell readme.php)

```
<html><head><meta http-equiv='Content-Type' content='text/html; charset=Windows-1251'><title>agx.vn - WSO 2.5</title>
<style>
body{background-color:#444;color:#e1e1e1;}
body,td,th{ font: 9pt Lucida,Verdana;margin:0;vertical-align:top;color:#e1e1e1; }
table.info{ color:#fff;background-color:#222; }
span,h1,af{ color: #00ff00 !important; }
span{ font-weight: bold; }
h1{ border-left:5px solid #00ff00;padding: 2px 5px;font: 14pt Verdana;background-color:#222;margin:0px; }
div.content{ padding: 5px;margin-left:5px;background-color:#333; }
af{ text-decoration:none; }
a:hoover{ text-decoration:underline; }
.mli{ border:1px solid #444;padding:5px;margin:0;overflow: auto; }
.bigarea{ width:100%;height:300px; }
input,textarea,select{ margin:0;color:#fff;background-color:#555;border:1px solid #00ff00; font: 9pt Monospace,'Courier New'; }
form{ margin:0px; }
#toolsTbl{ text-align:center; }
.toolsInp{ width: 300px; }
.main th{text-align:left;background-color:#5e5e5e;}
.main tr:hoover{background-color:#5e5e5e}
.l1{background-color:#444}
.l2{background-color:#333}
pre{font-family:Courier,Monospace;}
</style>
<script>
var c_ = '/home/agxvn/public_html/';
var a_ = 'FileManager';
var charset_ = 'Windows-1251';
var p1 = '';
var p2 = '';
var p3 = '';
var d = document;
function set(a,c,p1,p2,p3,charset) {
if(a!=null)d.mf.a.value=a;
if(c!=null)d.mf.c.value=c;else d.mf.c.value=c;
if(p1!=null)d.mf.p1.value=p1;else d.mf.p1.value=p1;
if(p2!=null)d.mf.p2.value=p2;else d.mf.p2.value=p2;
if(p3!=null)d.mf.p3.value=p3;else d.mf.p3.value=p3;
if(charset!=null)d.mf.charset.value=charset;else d.mf.charset.value=charset;
}
```

(ภาพโค้ดจาก readme.php)



การวิเคราะห์เชิงเทคนิค

1. Webshell (readme.php)

กลไกการทำงาน:

- FilesMan: จัดการไฟล์ (อัปโหลด, ลบ, แก้ไขสิทธิ์, บีบอัดไฟล์)

```
<ahref='#'onclick='g("FilesMan", "/home/agxvn/public_html/")'>public_h
tml/
</a>
```

คำอธิบายโค้ด: สืบเนื่องจากตัวแปร JavaScript Global var a_ = 'FilesMan' ซึ่งเป็นการตั้งค่า Default Action เป็นตัวจัดการไฟล์ และฟังก์ชัน g() ที่ใช้ส่งค่าพารามิเตอร์ FilesMan กลับไปที่ Server เพื่อขอจัดการไฟล์ใน Path ต่างๆ

- Console: รันคำสั่ง Linux Command Line (RCE)

```
<thwidth="16%">[<ahref="#"onclick="g('Console',null,',',',')">
Console</a> ]</th>
<form onsubmit="g('Console',null,this.c.value);return false;">
<span>Execute:</span><br>
<input class='toolsInp' type='text' name='c' value=''>
<input type='submit' value='>>'>
</form>
```

คำอธิบายโค้ด: พบ HTML Form ที่ส่งค่า c (Command) ไปยังฟังก์ชัน g('Console', ...) ซึ่งจะนำคำสั่งที่แยกเกอร์พิมพ์ในช่อง Input ไปประมวลผลด้วยฟังก์ชันระดับ OS บน Server

- Sql: เชื่อมต่อและจัดการฐานข้อมูล MySQL โดยตรง

```
<th width="16%">[ <a href="#" onclick="g('Sql',null,',',',')">Sql</a>
]</th>
```



คำอธิบายโค้ด: มีการกำหนด Action 'Sql' ในฟังก์ชัน JavaScript เพื่อเรียกหน้าจจัดการฐานข้อมูล ทำให้แฮกเกอร์สามารถรันคำสั่ง SQL Query หรือ Dump Database ได้

- **Self Remove:** ฟังก์ชันทำลายตัวเองเพื่อลบหลักฐาน

```
<th width="16%">[ <a href="#" onclick="g('SelfRemove',null,',',',')>Self  
remove</a> ]</th>
```

คำอธิบายโค้ด: พบคำสั่ง 'SelfRemove' ซึ่งเป็นพีเจอรันไทรที่สั่งให้ Webshell ลบไฟล์ตัวเองทิ้ง (unlink(__FILE__) ในฝั่ง PHP) หลังจากเสร็จภารกิจ เพื่อหลบเลี่ยงการตรวจสอบ

- **Sec. Info:** ดึงข้อมูลความปลอดภัยของ Server (Kernel version, User, Safe Mode)

```
<th width="16%">[ <a href="#" onclick="g('SecInfo',null,',',',')>Sec.  
Info</a> ]</th>
```

Linux cpanel-1.mona.host 4.18.0-372.9.1.lve.el8.x86_64 ...

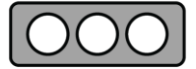
1057 (agxvn) Group: 1061 (agxvn)

7.4.33 Safe mode: OFF

คำอธิบายโค้ด: การเรียก Action 'SecInfo' หรือ 'Info' จะทำการดึงข้อมูล Environment ของเครื่อง (เช่น /etc/passwd, uname -a) มาแสดงผล

2. SEO Poisoning

- **Google Verification Files:** พบไฟล์ HTML สำหรับยืนยันตัวตนกับ Google Search Console จำนวนมาก เช่น google10084b52d444b7a7.html, google5a11e38a239bd90c.html แสดงว่าผู้ไม่ประสงค์ดีพยายามยึดสิทธิ์ความเป็นเจ้าของเว็บ
- **Random Directories:** พบโฟลเดอร์ชื่อสุ่มความยาว 5 ตัวอักษร เช่น 0af2f, 38555, 4e048, f1ca4 ภายในมักบรรจุสคริปต์สร้างหน้า Spam



- **License/Readme files:** พบไฟล์ license.txt, readme.html ที่ถูกแก้ไข timestamp เป็นวันที่ล่าสุดในปี 2025

3. Database Exfiltration Risks

- พบไฟล์ Dump ฐานข้อมูลขนาดใหญ่ เช่น agxvn_09052023.sql.gz, agxvn_13062023.sql.gz อยู่ในโฟลเดอร์สาธารณะ สามารถดาวน์โหลดออกไปได้ทันที-

Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Resource Development	T1588.002	Web Shell
Initial Access	T1190	Exploit Public-Facing Application
Persistence	T1505.003	Server Software Component: Web Shell
	T1136.001	Create Account: Local Account
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name
Command and Control	T1071.001	Application Layer Protocol: Web Protocols
Impact	T1496	Resource Hijacking
Collection	T1005	Data from Local System



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

File Name

readme.php

MD5

dbee6f660376b9259a108ff2349e123e

SHA-1

723fb7f7bd084974a881d99fe9cb45e54dddeeb0

SHA-256

6e7bf606ab141335070ceaa8150b4bf77b46adbb99346f8eaf20ac24c18d84c8



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบความเปลี่ยนแปลงของไฟล์ : ติดตั้งระบบหรือเปิดใช้งานฟังก์ชันเพื่อตรวจสอบการสร้างไฟล์ใหม่ หรือการแก้ไขไฟล์ในโพลเดอร์สำคัญของ Web Application โดยเฉพาะโพลเดอร์ที่เปิดให้อัปโหลดไฟล์ได้
- เฝ้าระวังการเรียกใช้งานไฟล์สคริปต์ด้วย HTTP Method: POST ที่มีความถี่สูงผิดปกติ หรือมาจาก IP Address ที่ไม่คุ้นเคย
- เฝ้าระวังการเชื่อมต่อเครือข่าย (Network Monitoring): ตรวจสอบ Traffic ขาออกจาก Web Server ว่ามีการพยายามเชื่อมต่อไปยังพอร์ตแปลกปลอม หรือ IP ปลายทางที่มีประวัติเป็น Malicious (C2 Server) หรือไม่

การป้องกัน (Prevention)

- อัปเดตระบบ: ดำเนินการอัปเดตระบบปฏิบัติการ และซอฟต์แวร์ CMS ให้เป็นเวอร์ชันล่าสุด เพื่อปิดช่องโหว่ที่เปิดโอกาสให้ผู้โจมตีเจาะระบบเข้ามาได้
- ตรวจสอบความปลอดภัยของการอัปโหลดไฟล์: ตรวจสอบไฟล์ที่อัปโหลดอย่าง เพื่อป้องกันเทคนิคการปลอมแปลง และปิดการรันสคริปต์ในโพลเดอร์ Upload
- ติดตั้ง Web Application Firewall (WAF): เพื่อช่วยกรอง Traffic อันตรายและบล็อกรูปแบบการโจมตีก่อนที่จะเข้าถึงตัว Server

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ : หากตรวจพบการบุกรุกหรือการทำงานของ Webshell ให้รีบตัดการเชื่อมต่อเครื่อง Server นั้นออกจากเครือข่ายภายนอกทันที เพื่อป้องกันการส่งการระยะไกล (C2) หรือการใช้เครื่องเป็นฐานโจมตีต่อไปยังเครื่องอื่น (Lateral Movement)
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics) เก็บสำรอง Log Files และตัวอย่างไฟล์ Webshell ที่พบไว้เพื่อวิเคราะห์หาวิธีการเจาะระบบ (Initial Access) และเตรียมป้องกันการถูกโจมตีซ้ำในรูปแบบเดิม
- กำจัดภัยคุกคาม : ลบไฟล์ Webshell หลักและค้นหาไฟล์ Backdoor ที่ถูกฝังไว้ทั้งหมด โดยใช้ข้อมูล IOCs พร้อมทั้งตรวจสอบ Scheduled Task (Cron Jobs) ว่ามีการฝังคำสั่งให้ดาวน์โหลด Webshell กลับมาใหม่หรือไม่



- กู้คืนระบบ: กู้คืนระบบจาก Backup ที่ปลอดภัยหลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและแก้ไขช่องโหว่ต่าง ๆ
- รีเซ็ตรหัสผ่าน: เปลี่ยนรหัสผ่านของผู้ดูแลระบบ, รหัสผ่านฐานข้อมูล, FTP, และ SSH ทั้งหมดทันที เนื่องจากมีความเสี่ยงสูงที่รหัสผ่านชุดเดิมจะถูกขโมยผ่าน Webshell ไปแล้ว
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th